PRE-GIT PUSH SECURITY AUDIT REPORT

Comprehensive DevSecOps & Git Vulnerability Assessment | Complete Workspace Scan

TARGET WORKSPACE	AUDIT MODE	SCAN DATE	AUDITOR ROLE
EFV-F-main (Frontend + Backend)	Read-Only / Zero-Mutation	November 3, 2026	Senior Git DevSecOps Auditor

VERDICT: DO NOT PUSH TO GITHUB (CRITICAL RISK)

Multiple active P0 Critical vulnerabilities identified, including hardcoded plaintext admin credentials, master live API keys, confidential roadmap/patent specs in base64, and cloud infrastructure endpoints.

3	4	5	18
P0 CRITICAL FINDINGS	P1 HIGH RISK FINDINGS	P2 MEDIUM FINDINGS	JSON FILES AUDITED

1. EXECUTIVE SUMMARY

This comprehensive security audit was executed upon the `EFV-F-main` project repository prior to any Git commit or remote push operation. Following a confirmed security incident in an adjacent project where JSON-stored data was exposed, this audit applied exhaustive static code analysis, regex pattern matching, credential scanning, and Git exposure modeling across all 205 project files (totaling 191 MB).

Key Audit Outcome: Under no circumstances should this repository be pushed to GitHub in its present state. The audit discovered:

- **Plaintext Admin Credentials:** Hardcoded administrative email `admin@uwo24.com` and passwords (`efv@2026` / `efv@1234`) in client-side code (`public/js/cart.js`).
- **Master Application API Key:** Hardcoded production API key `key_efv_live_master_2026` embedded across four separate files and passed in client HTTP headers (`X-Application-Key`).
- **Proprietary Strategy & IP Document Leak:** A 201 KB complete internal business roadmap, tokenomics, hardware specs, and patent strategy PDF base64-embedded directly into public web script `public/js/efv-pdf-data.js` and loaded onto all public pages.
- **Infrastructure Exposure:** Hardcoded Google Cloud Run service URLs (revealing GCP Project Numbers 246449377479 and 743928421487) and OAuth 2.0 Client IDs.
- **Internal Environment Dumps:** Over 500 KB of local Windows workstation diagnostic logs in `tool/` exposing developer usernames (`shiva`) and local drive filepaths.

2. PROJECT FOLDER & ARCHITECTURE ANALYSIS

Component	Location / Path	Classification	Security Exposure Risk
Frontend Core (Next.js 15)	`src/app/`, `src/components/`	Next.js App Router	High (hardcoded API key fallback, cloud run endpoints)
Frontend Static Assets	`public/`, `public/pages/`, `public/js/`	Static Web Assets	Critical (hardcoded admin passwords, base64 IP PDF, backup files)
Backend API Route	`src/app/api/config.js/route.ts`	Server-side Next.js route	Medium (dynamic config generator, fallback to localhost)

Component	Location / Path	Classification	Security Exposure Risk
CI/CD & Cloud Build	`cloudbuild.yaml`, `Dockerfile`	DevOps / GCP Deploy	High (hardcoded OAuth Client IDs & Cloud Run target)
Reverse Proxy Config	`nginx.conf`	Web Server	Safe (Standard static server config, no credentials)
Developer Tooling / Logs	`tool/`	Diagnostic & Scrap files	High (local machine paths, build crash logs, UTF-16 dumps)
Git Status	Workspace root	Uninitialized	Critical: .gitignore only excludes 1 file; 204 files would push

3. CRITICAL & HIGH FINDINGS SUMMARY TABLE

ID	Sev	File Path	Type of Sensitive Data	Git Status	Next Push
SEC-001	P0	`public/js/cart.js`	Plaintext Admin Passwords & Backdoor Check	Untracked	WOULD PUSH
SEC-002	P0	`UWOLoginModal.tsx`, `LibraryDashboard.tsx`, `dashboard/page.tsx`, `cart.js`	Master Application API Key (`key_efv_live_...`)	Untracked	WOULD PUSH
SEC-003	P0	`public/js/efv-pdf-data.js`	Proprietary Tech Strategy & Tokenomics PDF (201KB base64)	Untracked	WOULD PUSH
SEC-004	P1	`api-config.js`, `api-config.bak.js`, `cloudbuild.yaml`, `api.ts`	Production Cloud Run URLs & GCP Project IDs	Untracked	WOULD PUSH
SEC-005	P1	`cloudbuild.yaml`, `api-config.js`, `cart.js`	Google OAuth 2.0 Client IDs (2 unique project IDs)	Untracked	WOULD PUSH
SEC-006	P1	`tool/lint_output.txt`, `build_log.txt`, `lint_out.json`	Developer Machine Paths & Workstation Usernames (`shiva`)	Untracked	WOULD PUSH
SEC-007	P1	`public/js/api-config.bak.js`	Stray Backup File with Legacy Cloud Run URL in Public Web	Untracked	WOULD PUSH
SEC-008	P2	`admin.js`, `profile.js`, `cart.js`	Client-side Admin Privilege Escalation via LocalStorage	Untracked	WOULD PUSH
SEC-009	P2	`public/assets/fix_hamburger*.ps1`	PowerShell Maintenance Scripts with Local Drive Paths	Untracked	WOULD PUSH
SEC-010	P2	`public/package-lock.json`	Stray Lockfile in Static Web Root	Untracked	WOULD PUSH
SEC-011	P2	`public/assets/images/` (Duplicates & Videos)	Over 45 MB of duplicated assets and video files	Untracked	WOULD PUSH

4. DETAILED FINDINGS BREAKDOWN

SEC-001: Plaintext Admin Account Credentials & Authentication Check

P0 CRITICAL

Location: `public/js/cart.js` (lines 2730–2736)
Evidence (Masked): `if (email === 'admin@uwo24.com' && (password === 'efv@2***' || password === 'efv@1***')) { ... }`
Impact: Plaintext administrator passwords and email are completely exposed to anyone inspecting the frontend files or browsing GitHub. An attacker can directly authenticate as administrator on production.

Remediation: Immediately delete the plaintext check from `cart.js`. Change the admin password in the backend database immediately. Enforce JWT-based password verification on the backend API only.

SEC-002: Master Live Application API Key Hardcoded in Source Code

P0 CRITICAL

Location: `src/components/Common/UWOLoginModal.tsx`, `src/components/Library/LibraryDashboard.tsx`, `src/app/dashboard/page.tsx`, `public/js/cart.js`
Evidence (Masked): `apiKey = 'key_efv_live_master_2***'` passed in header `X-Application-Key`.
Impact: The master live API key grants unrestricted programmatic access to user registration, password reset, and session issuance on the unified auth API (`https://uwo24.com/api`).

Remediation: Move application key validation to server-side Next.js route handlers. Never expose `key_efv_live_master_*` in client-side code. Rotate the API key in the unified auth database immediately.

SEC-003: Confidential Business Architecture & Patent Strategy in Public Script

P0 CRITICAL

Location: `public/js/efv-pdf-data.js` (loaded across 5 public HTML pages)
Evidence: 201 KB Base64 PDF string containing *"EFV Framework™ – Complete App & Tech Work + Documentation Checklist"* covering Phase 1–8: Tokenomics (EFV Coin™), Watch hardware specs, royalties, licensing models, and AI engine architecture.
Impact: Irreversible loss of intellectual property, trade secrets, and competitive advantage once published to GitHub.

Remediation: Remove `public/js/efv-pdf-data.js` immediately. Remove all `<script src="../js/efv-pdf-data.js">` tags from HTML pages. If reader previews are required, serve sanitized public samples from private cloud storage.

SEC-004: Direct Google Cloud Run Service URLs & GCP Project IDs

P1 HIGH

Location: `public/js/api-config.js`, `cloudbuild.yaml`, `src/lib/api.ts`, `src/context/AuthContext.tsx`
Evidence: `https://efv-b-246449377479.asia-south1.run.app` and `https://efvbackend-743928421487.asia-south1.run.app`
Impact: Exposes internal cloud infrastructure topology, service names, and Google Cloud Project identifiers (246449377479, 743928421487), enabling direct denial-of-service, API fuzzing, and reconnaissance.

Remediation: Use custom domain DNS routing (e.g., `https://api.efvframework.com`) through Cloud Armor / API Gateway. Pass endpoints via environment variables at runtime, never hardcoded fallbacks.

SEC-005: Developer Machine Paths & Diagnostic Dumps in tool/

P1 HIGH

Location: `tool/lint_output.txt` (493KB), `tool/build_log.txt`, `tool/lint_out.json`, `public/js/grep_location.txt`
Evidence: Windows drive paths (`F:\EFVFINAL\VHA\EFV-F\...`, `C:\Users\shiva\...`), developer username `shiva`, and full source code excerpts.
Impact: Exposes internal operating system topography, username naming conventions, and local workstation layout.

Remediation: Completely add `tool/` to `.gitignore` and delete local diagnostic dumps before pushing.

5. COMPLETE JSON DATA SECURITY AUDIT (PHASE 3)

Given that an adjacent project in the repository was compromised via exposed JSON records, all 18 JSON files were audited individually for credentials, PII, and internal configurations:

File Path	File Purpose	Sensitive Data / PII Status	Git Status	Verdict
`package.json`	Next.js project configuration	None. Contains standard npm scripts and dependencies.	Untracked	SAFE TO PUSH
`package-lock.json`	NPM dependency tree lock	None. Standard dependency hash registry.	Untracked	SAFE TO PUSH
`public/package-lock.json`	Duplicate / stray npm lockfile	Stray file in public web directory exposing project internals.	Untracked	DO NOT PUSH
`tsconfig.json`	TypeScript compiler options	None. Standard compiler configuration.	Untracked	SAFE TO PUSH
`tool/lint_out.json`	UTF-16 ESLint execution dump	Contains developer workstation filepaths (`F:\EFVFINAL...`) and source excerpts.	Untracked	DO NOT PUSH
`tool/lint_out_utf8.json`	UTF-8 ESLint execution dump	Contains developer workstation filepaths and internal AST error logs.	Untracked	DO NOT PUSH
`public/locales/en.json`	English UI translations	Clean. Contains placeholder strings (`email@example.com`).	Untracked	SAFE TO PUSH
`public/locales/hi.json`	Hindi UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH
`public/locales/es.json`	Spanish UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH
`public/locales/ar.json`	Arabic UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH
`public/locales/ja.json`	Japanese UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH
`public/locales/ko.json`	Korean UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH

File Path	File Purpose	Sensitive Data / PII Status	Git Status	Verdict
`public/locales/zh-CN.json`	Chinese UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH
`public/locales/ru.json`	Russian UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH
`public/locales/de.json`	German UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH
`public/locales/it.json`	Italian UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH
`public/locales/fr.json`	French UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH
`public/locales/pt.json`	Portuguese UI translations	Clean. Standard localization dictionaries.	Untracked	SAFE TO PUSH

6. GIT TRACKING & REPOSITORY ANALYSIS (PHASE 7 & 8)

Git Parameter	Current State in Local Workspace	Security Risk / Assessment
Git Initialization Status	`fatal: not a git repository: .git`	Workspace has no active `.git` repository directory.
Tracked Files	0 files	No files are currently recorded in a local Git index.
Staged Files	0 files	No files staged for immediate commit.
Ignored by .gitignore	1 file (`next-env.d.ts`)	**CRITICAL FLAW:** 204 out of 205 files are NOT ignored.
Projected Push Exposure	**204 files (191 MB)**	Running `git init && git add .` will immediately stage all P0, P1, and P2 secrets.
Local Commit History	None (Clean Working Tree)	No local history leaks exist; secrets are not yet baked into Git objects.
Remote Repository Exposure	Not configured locally	External GitHub references point to `github.com/EFV-Official/EFV-Website`.

7. .GITIGNORE SECURITY DEFICIENCIES (PHASE 9)

The current `.gitignore` file is dangerously incomplete. It only ignores `.env*`, `node_modules/`, `.next/`, `*.tsbuildinfo`, and `next-env.d.ts`. It fails to exclude:

[MISSING] **Backup files:** `*.bak`, `*.backup`, `*.old` are missing (permitting `public/js/api-config.bak.js`).

[MISSING] **Diagnostic and log directories:** `tool/` and `*.log` are not fully ignored (permitting `build_log.txt` and `lint_output.txt`).

[MISSING] **Scratch scripts:** `*.ps1`, `fix*.js`, `rename*.js`, `inject*.js` are untracked and eligible for commit.

[MISSING] **Large binary media:** Video files (`*.mp4`) and uncompressed duplicate images (`* - Copy.*`) are not excluded.

[MISSING] **Embedded base64 confidential files:** `public/js/efv-pdf-data.js` is completely unprotected.

8. ACTION PLAN & REMEDIATION (BEFORE GIT INIT & PUSH)

1. **Remediate P0 Admin Passwords:** Open `public/js/cart.js` and delete lines 2730–2736 (hardcoded check for `admin@uwo24.com` with passwords `efv@2026` / `efv@1234`). Rotate admin passwords on production.
2. **Remediate P0 Master API Key:** Remove `key_efv_live_master_2026` from `UWOLoginModal.tsx`, `LibraryDashboard.tsx`, `dashboard/page.tsx`, and `cart.js`. Issue API requests via backend Next.js API routes with server-side secrets.
3. **Purge Confidential Tech PDF:** Delete `public/js/efv-pdf-data.js` and remove corresponding script tags from `profile.html`, `blogs.html`, `blog-detail.html`, `admin-dashboard.html`, and `marketplace.html`.
4. **Delete Developer Dumps & Tooling:** Delete `public/js/api-config.bak.js`, `public/package-lock.json`, `public/js/grep_location.txt`, and the entire `tool/` folder.
5. **Purge Duplicate Large Media:** Delete all duplicate images matching `* - Copy.*` (saves ~45 MB). Offload `EFV(VIDEO).mp4` and `EFV-Cover Volume 1 (ENGLISH).pdf` to CDN/cloud storage.
6. **Update .gitignore:** Add `tool/`, `*.bak`, `*.log`, `*.ps1`, `public/js/api-config.bak.js`, and `*.mp4` to `.gitignore`.
7. **Initialize Clean Git Repository:** After executing steps 1–6, run `git init`, verify `git status`, and proceed with a safe initial commit.

9. FINAL VERDICT & QUESTION ANSWER

Final Answer to: ***"Is my complete frontend and backend project safe to push to GitHub right now?"***

NO. YOUR PROJECT IS NOT SAFE TO PUSH TO GITHUB RIGHT NOW.

Pushing the project in its current condition will expose production admin passwords, master API keys, proprietary corporate trade secrets, and internal cloud infrastructure. Remediate all P0 and P1 findings prior to running `git add` or pushing to any public or private remote repository.